

DOCUMENTAÇÃO TÉCNICA

LexIA

Esquema de dados, funcionalidades e segurança da plataforma

Projeto: BelaBet/lexia-app

Backend: Supabase (Postgres + Auth + Storage + Edge Functions)

Frontend: React + TypeScript + Vite

Documento gerado em 04/09/2026

1. Visão Geral

O LexIA é um SaaS jurídico multi-tenant: cada escritório/advogado tem sua própria conta, isolada das demais, e usa o sistema para gerenciar processos, publicações/movimentações importadas de provedores externos, documentos, agenda, checklists de obrigações e um portal para os próprios clientes acompanharem o andamento dos seus casos.

1.1 Arquitetura

Camada	Tecnologia
Frontend	React 18 + TypeScript + Vite, Tailwind CSS, shadcn/ui, TanStack Query, react-router-dom
Backend	Supabase — Postgres (com Row Level Security), Auth, Storage, Edge Functions (Deno)
Integrações externas	JusBrasil, WebJur e Escavador (monitoramento processual), OpenAI (IA), ClickUp, Stripe (planos)
Hospedagem/deploy	Vercel (frontend) + Supabase Cloud (backend)
Gerenciador de pacotes	bun

1.2 Modelo de acesso

Cada linha de dado sensível (processo, publicação, documento, evento, checklist etc.) pertence a um `user_id` — o escritório dono. O isolamento entre contas é garantido no próprio banco de dados via Row Level Security (RLS), não apenas na interface, então nenhuma tela do sistema consegue "vazar" dado de outro escritório mesmo que tentasse. Detalhes completos na Seção 4.

2. Esquema de Dados

O banco tem 31 tabelas no schema `public`, todas com RLS ativado. Estão organizadas por domínio funcional:

2.1 Núcleo do escritório (Casos, Documentos, Agenda)

Tabela	Descrição	Campos-chave
<code>cases</code>	Processos/casos jurídicos do escritório	<code>case_number</code> , <code>title</code> , <code>client</code> , <code>parte_diversa</code> , <code>vara</code> , <code>comarca</code> , <code>valor_causa</code> , <code>data_abertura_tribunal</code> , <code>data_aceitacao</code> , <code>status</code> (active/pending/closed)
<code>documents</code>	Documentos jurídicos criados/gerenciados no sistema	<code>title</code> , <code>type</code> , <code>content</code> , <code>status</code>
<code>document_shares</code>	Compartilhamento de documentos entre usuários	<code>document_id</code> , <code>shared_by</code> , <code>shared_with</code> , <code>permission</code> (view/edit)
<code>events</code>	Agenda — também funciona como gerenciador de tarefas	<code>title</code> , <code>event_date</code> , <code>event_time</code> , <code>type</code> , <code>case_id</code> , <code>publication_id</code> , <code>status</code> (pending/in_progress/completed/overdue/cancelled), <code>priority</code>
<code>event_participants</code> / <code>event_attachments</code>	Convidados e anexos de um evento	<code>event_id</code> + dados do participante/arquivo
<code>chat_history</code>	Histórico de conversas com o Assistente IA	<code>messages</code> (jsonb), <code>document_id</code>

2.2 Publicações e monitoramento processual (APIs externas)

Tabela	Descrição	Campos-chave
<code>publications</code>	Publicações/movimentações — manuais ou importadas via API	<code>process_number</code> , <code>source</code> (jusbrasil/webjur/escavador/manual/outro), <code>content</code> , <code>published_date</code> , <code>external_deadline</code> , <code>internal_deadline</code> , <code>vara</code> , <code>comarca</code> , <code>valor_causa</code> , <code>datas_processuais</code> , <code>imported_automatically</code> , <code>raw_payload</code>
<code>publication_integrations</code>	Credenciais/config de cada integração (uma por fonte e conta)	<code>source</code> , <code>webhook_secret</code> , <code>api_key</code> , <code>monitor_document</code> (CPF/CNPJ), <code>monitor_oab</code> , <code>price_per_search</code> , <code>last_poll_status</code>
<code>publication_attachments</code>	Documentos anexados a uma publicação (upload manual ou baixado automaticamente da API)	<code>publication_id</code> , <code>file_path</code> , <code>source</code> (manual/api)
<code>publication_followups</code>	Anotações de acompanhamento em uma publicação	<code>publication_id</code> , <code>note</code>
<code>process_search_charges</code>	Contador financeiro — 1 registro por pesquisa processual realizada (busca ativa diária ou manual)	<code>integration_id</code> , <code>document</code> , <code>document_type</code> (cpf/cnpj/oab), <code>search_type</code> (manual/poll), <code>unit_price</code> , <code>charged_amount</code>

2.3 Checklists e obrigações

Tabela	Descrição
checklist_templates / checklist_template_items	Modelos reutilizáveis de checklist (contexto: caso, cliente ou geral; com recorrência)
checklists / checklist_items	Checklists ativos vinculados (opcionalmente) a um caso, com status e prioridade
checklist_alerts	Lembretes agendados de itens/checklists
obligation_history	Histórico de cumprimento de obrigações (para métricas de pontualidade)

2.4 Portal do Cliente ("Meu Jurídico")

Tabela	Descrição
clients	Cadastro do cliente do escritório; pode ou não ter login próprio no portal (user_id)
case_clients	Vínculo N:N entre casos e clientes com acesso ao portal
case_timeline_events	Linha do tempo do processo em linguagem simples para o cliente (traduzida por IA), com controle de visibilidade
client_requests	Solicitações do advogado ao cliente (documento, assinatura, questionário)
client_documents	Documentos trocados entre advogado e cliente dentro de um caso

2.5 Plataforma, contas e administração

Tabela	Descrição
profiles	Dados de perfil do usuário (nome, OAB, especialidade)
user_roles	Papéis do usuário na plataforma (user/premium/admin/supremo) — ver Seção 4.2
notifications	Notificações in-app
feature_requests	Solicitações de funcionalidade enviadas à equipe
white_label_settings	Marca da plataforma (nome, logo, cores) — linha única, editável só por admin
clickup_integrations	Integração com ClickUp — exclusiva para role supremo
api_usage	Rate limiting de uso de IA por usuário/função
legal_chat_requests	Log de uso do assistente jurídico de IA

2.6 Storage (arquivos)

Bucket	Público?	Conteúdo
event-files	Não	Anexos de eventos da Agenda
client-documents	Não	Documentos trocados no Portal do Cliente
publication-attachments	Não	Documentos anexados a publicações (manual ou automático via API)
branding	Sim	Logo e assets visuais da marca da plataforma (não contém dado sigiloso)

3. Funcionalidades

Os módulos abaixo seguem a ordem atual do menu principal.

Dashboard

Visão geral com indicadores (Documentos, Processos Abertos, Processo Baixado, Prazos Próximos), atalhos rápidos, documentos recentes e próximos prazos.

Publicações

Central de publicações/movimentações processuais — cadastradas manualmente ou importadas automaticamente via webhook/busca ativa do JusBrasil, WebJur e Escavador. Cada publicação traz dados processuais destacados (vara, comarca, valor da causa, datas), prazos externo/interno (que geram evento automático na Agenda), documentos anexados (upload manual ou automático) e histórico de acompanhamento.

Processos

Gestão de casos/processos do escritório: dados da parte, parte diversa, dados processuais (vara, comarca, valor da causa, datas de abertura/aceitação), status (ativo/pendente/encerrado) e vínculo com clientes do portal. Casos podem ser criados manualmente ou abertos automaticamente quando uma publicação nova chega via API.

Agenda

Calendário de compromissos, audiências e prazos — inclui os prazos criados automaticamente a partir de publicações. Também funciona como gerenciador de tarefas: cada evento pode ter status (pendente/em andamento/concluído/atrasado/cancelado) e prioridade, com painel unificado que mostra eventos e itens de checklist juntos por dia.

Meus Documentos / Criar Documento

Repositório de documentos jurídicos com compartilhamento (visualização ou edição) entre usuários, e criação assistida de documentos.

Assistente IA / Leitor de PDF

Chat jurídico com IA (com limite de uso por usuário) e leitor de PDF com análise assistida.

Contador Financeiro

Quantidade e valor cobrado do cliente por CNPJ/CPF/OAB monitorado em cada pesquisa processual via API — soma buscas ativas diárias e buscas manuais (botão "Buscar agora" em Integrações), com filtro por período.

Checklists

Checklists de obrigações recorrentes ou pontuais, com modelos reutilizáveis, prazos por item e histórico de cumprimento.

Portal do Cliente ("Meu Jurídico")

Convite de clientes por e-mail (login próprio), linha do tempo do processo traduzida para linguagem simples, solicitações de documento/assinatura/questionário e troca de documentos — tudo restrito ao caso específico do cliente.

Integrações

Configuração de credenciais (URL + segredo de webhook, chave de API) para JusBrasil, WebJur e Escavador; configuração de busca ativa diária (CPF/CNPJ/OAB monitorado, valor por pesquisa) e busca manual sob demanda.

Configurações / Administração

Preferências da conta, planos e pagamento, marca da plataforma (white-label, restrito a admin) e painel de administração de usuários e roles (restrito a admin/supremo).

4. Segurança

4.1 Isolamento entre contas (multi-tenant)

Todas as 31 tabelas do schema `public` têm Row Level Security ativado. A regra geral, confirmada tabela por tabela, é:

Padrão de acesso	Onde se aplica
DONO <code>auth.uid() = user_id</code>	Casos, Publicações, Documentos, Eventos, Checklists, Notificações, Integrações, Contador Financeiro, Perfil, etc. — cada usuário só lê/escreve os próprios dados.
COMPARTILHADO funções <code>is_case_owner</code> / <code>is_case_client</code> / <code>is_publication_owner</code>	Portal do Cliente (<code>case_clients</code> , <code>client_requests</code> , <code>client_documents</code> , <code>case_timeline_events</code>) e anexos de publicação — acesso liberado só para o advogado dono do caso e o(s) cliente(s) vinculado(s) a ele.
ADMIN função <code>has_role(uid, 'admin')</code>	Gerenciar roles de outros usuários, ver todas as solicitações de funcionalidade, editar marca da plataforma.
PÚBLICO	Apenas <code>white_label_settings</code> (leitura) e o bucket <code>branding</code> — conteúdo não sigiloso (nome/logo/cores da plataforma).

Os buckets de arquivo seguem o mesmo modelo: `client-documents` e `publication-attachments` usam políticas de storage que checam o dono/cliente do caso ou da publicação a partir do primeiro segmento do caminho do arquivo, então um usuário não consegue montar uma URL para ler o arquivo de outra conta.

4.2 Hierarquia de papéis (roles)

Independente do isolamento por conta, quatro papéis controlam o que cada pessoa pode fazer na plataforma (uma mesma conta pode acumular mais de um):

Role	O que controla de fato
<code>user</code>	Papel base — acesso normal aos próprios dados.
<code>premium</code>	Apenas indicação visual (qual plano aparece marcado) — não restringe nenhuma tabela ou função no banco hoje.
<code>supremo</code>	Único papel que trava um recurso real: a integração com ClickUp (tabela <code>clickup_integrations</code> é 100% restrita a supremo).
<code>admin</code>	Painel de Administração completo: gerenciar roles de outros usuários, ver feature requests de todos, editar white-label. A função <code>admin-update-role</code> impede que um admin comum altere ou promova alguém a supremo — só outro supremo pode.

4.3 Edge Functions (Deno) — autenticação por rota

Função	Quem pode chamar
<code>publication-webhook</code>	Pública, mas exige o segredo de webhook específico daquele usuário/fonte (header <code>x-webhook-secret</code>) — só grava dado na conta certa se o segredo bater.
<code>poll-jusbrasil</code>	Restrita à Service Role Key (o agendamento diário) — corrigida nesta revisão (ver 4.4).
<code>manual-process-search</code>	Usuário autenticado; valida que a integração pertence a quem chamou antes de rodar.
<code>invite-client</code> , <code>humanize-timeline-event</code>	Usuário autenticado; confirmam que o caso pertence a quem chamou antes de agir.

<code>admin-update-role</code>	Usuário autenticado com role admin (e checagem extra para alterar/promover supremo).
Demais (IA, checkout, portal de cobrança etc.)	Usuário autenticado; operam sobre o próprio usuário ou dados já protegidos por RLS.

4.4 Revisão de segurança realizada e correção aplicada

CORRIGIDO — VAZAMENTO ENTRE CONTAS EM POLL-JUSBRASIL

A função que roda a busca ativa diária processava as integrações JusBrasil de **todas** as contas de uma vez e devolvia, na resposta, o `user_id` e o resultado da busca de cada uma. Como o `verify_jwt` do Supabase só garante que o token é válido — não que é o agendamento chamando — qualquer usuário autenticado do sistema poderia ter chamado essa rota diretamente com o próprio login e visto dados de outras contas/escritórios, além de disparar buscas (e gerar cobranças) em integrações que não eram dele.

Correção: a função agora exige que o cabeçalho Authorization seja exatamente a Service Role Key (a mesma que o agendamento já usa), recusando com 403 qualquer chamada feita com token comum de usuário. A resposta também passou a trazer só contagens agregadas, nunca a lista de contas processadas.

OBSERVAÇÕES DO LINTER DE SEGURANÇA (NÃO SIGILOSO, BAIXO RISCO)

- Extensão `pg_net` instalada no schema `public` em vez de um schema próprio — recomendação de organização do Supabase, sem exposição de dado.
- Diversas funções auxiliares (`has_role`, `is_case_owner`, `is_case_client`, `is_publication_owner` etc.) são `SECURITY DEFINER` e tecnicamente chamáveis por qualquer usuário autenticado — mas todas usam `auth.uid()` internamente e só retornam um booleano, então chamá-las diretamente não expõe nenhum dado, só confirma se a pessoa é dona ou não daquele registro.
- Proteção contra senhas vazadas (HaveIBeenPwned) está desativada nas configurações de Auth do Supabase — recomenda-se ativar em Authentication → Policies.

4.5 Segredos e credenciais

- Chaves de API de provedores externos (JusBrasil etc.) ficam em `publication_integrations.api_key`, protegida pela mesma RLS por dono — nenhum outro usuário consegue ler a chave de outra conta.
- O webhook de cada integração usa um segredo próprio por usuário/fonte (`webhook_secret`), regenerável a qualquer momento pela tela de Integrações.
- A Service Role Key usada pelo agendamento diário fica guardada de forma criptografada no Vault do Supabase, não em texto puro em nenhuma tabela.